

ECOM EXPERTS

Ecom shield

Manual de usuario, tecnico y de desarrollo

ecom_shield 1.7.0 · 07/09/2026

Contenido

1. ¿Qué hace GravityShield?

2. Acceso al módulo

3. Configuración Principal

3.1 Modo Bloqueo Activo (Frecuencia)

3.2 Geo-Blocking Activo

3.3 Lista Blanca de IPs

3.4 Bots Bloqueados (User-Agent)

3.5 IPs Bloqueadas

4. Panel de Estadísticas — Bots & IPs

4.1 Tabla: Top Bots / User-Agents

4.2 Tabla: Top IPs por Hits

5. Logs de Seguridad

Columnas del log

Herramientas de log

6. Mantenimiento de la Base de Datos GeoIP

Descargar DB GeoIP Masiva

Recalcular Países (botón en Logs)

7. Flujo de bloqueo (prioridades)

8. Resolución de problemas

Un cliente real está siendo bloqueado

El geo-bloqueo bloquea a clientes de mi país

La tabla de Bots aparece vacía

Los hits aparecen como 0

9. Changelog

v1.2.2 — 2026-03-26

v1.2.1 — 2026-03-26

v1.2.0 — 2026-03-26

v1.1.1 — anterior

10. Soporte

Novedades de la versión 1.6.0

La "Fase 0" ahora funciona de verdad

Base de datos GeoIP mucho más ligera

Otras mejoras de rendimiento

Novedades de la versión 1.7.0 — rendimiento

Tu tienda (front)

El panel de administración

Base de datos

Si "Descargar GeoIP Local" da error

Si tu módulo de seguridad avisa de cambios en config/

"Fichero eliminado: config/early_injection.php" (severidad alta)

"Fichero modificado: config/defines_custom.inc.php"

1. Instalación y Puesta en Marcha

2. Configuración Principal

3. Registros de Seguridad (Logs)

4. Mantenimiento

Overview

Architecture

Key Components

1. Persistent Logging (Database)

2. Back Office Controller

3. Detection Mechanisms

Mejoras de Seguridad y Rendimiento

 Observabilidad y Métricas

 Multi-fuente IA

4. Gmartos Connect Integration

Hooks Used

Configuration Modes

Fase 0 — enganche real en el arranque del core (v1.6.0)

Punto de inyección

Script generado (ecom_shield_early.php)

GeoIP: índice binario data/ip_ranges.bin (v1.6.0)

Formato

Por qué

Construcción

Compatibilidad

API de GeoLite

Optimización del path caliente y del back-office (v1.7.0)

Coste por petición de front

recordBlockedFast() — la inversión que había

getMetrics() — no había caché sin APCu

controllers/front/metrics.php

Migraciones: una vez por versión, no en cada carga

Índices de ecom_shield_log

Consultas del back-office

Recuento de hits bloqueados: el dedup limita escrituras, no cuentas

Caché del monitor y el reloj

Etiquetas de motivo normalizadas

Lista de bots SEO unificada

Robustez del índice binario

Caché de stat de PHP

Empaquetado seguro en PHP de 32 bits

Parseo del CSV

Otras salvaguardas

Origen de la base GeoIP (corregido)

Cambios

Importación real medida

Convivencia con módulos de integridad de ficheros

Reglas actuales

1. Arquitectura de Seguridad

2. Base de Datos

3. Dashboard Administrativo
3. Logs y Sincronización
4. Requisitos y Compatibilidad
Modifying Logic
Whitelist Customization
Testing & Validation
Configuration & Logs
Files Structure
Contributing
1. Personalización de Ganchos (Hooks)
2. Desarrollo de la Fase 0
3. Base de Datos Local GeoIP
4. Sincronización de Hits
5. Clasificación de Tráfico IA y Bots
6. Dashboard y Observabilidad
7. Estándares PrestaShop 8 y Traducciones
Standards & Compatibility
Database Management
Admin Controller Implementation
Hooks & Context
Optimización de Logs y Agrupación de Tráfico
API Connectivity
Fase 0 y GeoIP — reglas de mantenimiento (desde v1.6.0)
Tocar config/defines_custom.inc.php
Escribir en ecom_shield_early.php
GeoIP
Coste por petición: presupuesto
Reglas de rendimiento añadidas en v1.7.0
Configuración leída en el path de petición
Escrituras del buffer transitorio
Cachés

Migraciones y mantenimiento

SQL sobre ecom_shield_log

Controladores front del módulo

1. Introducción

2. Características Principales

3. Arquitectura Técnica

3.1. Base de Datos

3.2. Lógica de Agrupación

4. Sistema de Geolocalización

5. Detección de Amenazas

6. Panel de Administración

7. Hooks Implementados

8. Configuración (Gmartos Connect)

Versión: 1.2.2 **Autor:** Ecom Experts · ecomyseo@gmail.com **Compatibilidad:** PrestaShop 1.7+

1. ¿Qué hace GravityShield?

GravityShield protege tu tienda PrestaShop frente a:

- **Bots** de scraping, spam y ataques de alta frecuencia
- **Crawlers de IA** (GPTBot, ChatGPT, OpenAI, Amazon AI, etc.)
- **IPs maliciosas** con patrones de acceso automático
- **Tráfico de países no deseados** mediante geobloqueo

Todo el tráfico sospechoso queda registrado en los logs de seguridad para su revisión.

2. Acceso al módulo

- **Configuración:** Módulos > Module Manager > GravityShield > Configurar
- **Logs:** Parámetros Avanzados > GravityShield Logs

3. Configuración Principal

3.1 Modo Bloqueo Activo (Frecuencia)

Estado	Comportamiento
OFF (Simulación)	Registra las detecciones pero no bloquea. Recomendado los primeros días para detectar falsos positivos.
ON (Bloqueo)	Bloquea automáticamente con HTTP 403 cuando detecta frecuencia anormal (< 2s entre accesos).

3.2 Geo-Blocking Activo

Activa el bloqueo por país de origen del visitante.

- **Países Permitidos:** Lista de códigos ISO separados por coma (ej: `ES,FR,DE,IT,PT`). Solo estos países podrán acceder.
- Si el visitante viene de un país no incluido → recibe HTTP 403 automáticamente.

3.3 Lista Blanca de IPs

IPs que **nunca serán bloqueadas** bajo ninguna circunstancia (ni por geo, ni por frecuencia, ni por listado manual). Una IP por línea o separadas por comas.

Añade aquí siempre tu IP de oficina o de acceso habitual.

3.4 Bots Bloqueados (User-Agent)

Lista de **patrones de User-Agent** bloqueados permanentemente. Cualquier visita cuyo UA contenga uno de estos textos recibirá HTTP 403.

Un patrón por línea. Ejemplos:

```
Googlebot  
SemrushBot  
GPTBot  
AhrefsBot  
ChatGPT-User  
bingbot  
MJ12bot
```

Nota: El bloqueo por UA es exacto en minúsculas/mayúsculas. El sistema usa búsqueda parcial, por lo que `Semrush` bloquea también `SemrushBot` y `SemrushBot-SA`.

3.5 IPs Bloqueadas

Lista de **IPs bloqueadas manualmente**. Se bloquean con HTTP 403 antes de cualquier otra comprobación (excepto la lista blanca). Una IP por línea.

4. Panel de Estadísticas — Bots & IPs

Disponible en la parte inferior de la página de configuración. Muestra en tiempo real los principales bots e IPs detectados en los logs.

4.1 Tabla: Top Bots / User-Agents

Muestra todos los visitantes agrupados por IP y User-Agent con **≥ 3 hits totales**, ordenados de mayor a menor tráfico.

Columna	Descripción
Tipo	AI (bots de inteligencia artificial), Bot (crawlers/scrapers), User (tráfico humano)
Bot / IA Name	Nombre detectado automáticamente (Googlebot, ChatGPT, Semrush, etc.)
User-Agent	Cadena completa del navegador/bot (truncada a 75 caracteres, tooltip con el texto completo)
Hits Totales	Suma de todas las visitas registradas para esa combinación IP+UA
Última visita	Fecha y hora de la última actividad
Estado	Libre o Bloqueado

Para bloquear bots: 1. Marca la casilla de los bots que quieres bloquear 2. Haz clic en **BLOQUEAR Bots Seleccionados** 3. Sus User-Agents se añaden automáticamente al campo *Bots Bloqueados* de la configuración 4. A partir de ese momento, cualquier visita con ese UA recibe HTTP 403

Nota sobre registros antiguos: Los registros creados antes de la versión 1.2.0 no tienen User-Agent guardado. Aparecen con el texto "*No disponible (anterior a v1.2)*". A medida que esas IPs vuelvan a visitar la tienda, sus registros se actualizarán automáticamente con el UA real.

4.2 Tabla: Top IPs por Hits

Muestra las IPs con **≥ 5 hits totales**, ordenadas por volumen de tráfico.

Para bloquear IPs: 1. Marca la casilla de las IPs que quieres bloquear 2. Haz clic en **BLOQUEAR IPs Seleccionadas** 3. Las IPs se añaden automáticamente al campo *IPs Bloqueadas* de la configuración 4. A partir de ese momento reciben HTTP 403 en cada visita

5. Logs de Seguridad

Accede desde: [Parámetros Avanzados](#) > [GravityShield Logs](#)

Columnas del log

Columna	Descripción
IP	Dirección IP del visitante
País	Código ISO del país de origen
Contexto	<code>page_view</code> , <code>geo_block</code> , <code>bot_block</code> , <code>ip_block</code>
Hits	Número de accesos en la ventana de 1 hora
Media (seg)	Tiempo promedio entre accesos. En rojo si < 2s (posible bot)
¿Es Bot?	Flag automático
Bloqueado	Si el acceso fue denegado
Última actividad	Timestamp del último hit registrado

Herramientas de log

Herramienta	Acción
Recalcular Países	Re-geolocaliza hasta 500 IPs con país desconocido (--)
Limpiar Ruido	Borra registros con 1 solo hit que no son bots ni están bloqueados
Purgar Normales	Borra todo el tráfico no bloqueado
VACIAR TODO EL HISTORIAL	Trunca completamente la tabla de logs

6. Mantenimiento de la Base de Datos GeoIP

Descargar DB GeoIP Masiva

Descarga e instala la base de datos **DB-IP Lite** completa (~50 MB en disco) directamente desde GitHub.

- **Ventaja:** Geolocalización instantánea sin llamadas a APIs externas
- **Cuándo usarlo:** Si ves muchas IPs con país -- en los logs
- **Requisitos:** El servidor necesita al menos 512 MB de memoria y conexión a internet

Recalcular Países (botón en Logs)

Procesa hasta 500 IPs desconocidas usando la base de datos local y, si falla, la API de respaldo `ip-api.com`.

7. Flujo de bloqueo (prioridades)

Cuando llega una visita al front-office, el módulo comprueba en este orden:

1. ¿Está en Lista Blanca? → Permitir siempre (fin)
2. ¿Está en IPs Bloqueadas? → HTTP 403 (fin)
3. ¿Su User-Agent coincide con Bots Bloqueados? → HTTP 403 (fin)
4. ¿Geo-Blocking activo y país no permitido? → HTTP 403 (fin)
5. Registrar acceso normal → Permitir

8. Resolución de problemas

Un cliente real está siendo bloqueado

1. Ve a los logs y busca su IP
2. Revisa la columna **Contexto** para ver por qué fue bloqueado
3. Añade su IP a la **Lista Blanca**
4. Si no sabes su IP, activa el **Modo Simulación** temporalmente

El geo-bloqueo bloquea a clientes de mi país

- Verifica que el código ISO de tu país esté en la lista **Países Permitidos**
- España = **ES** , Francia = **FR** , etc.
- Los códigos deben estar en mayúsculas y separados por coma sin espacios

La tabla de Bots aparece vacía

- Normal si el módulo se acaba de actualizar a v1.2.0+
- Los registros anteriores no tienen User-Agent guardado
- A medida que llega nuevo tráfico, la tabla se rellena automáticamente
- Para acelerar el proceso, accede a **GravityShield Logs** y ejecuta **Recalcular Países** (esto también actualiza UAs en registros existentes que vuelven a visitar la tienda)

Los hits aparecen como 0

- Registros creados antes de v1.2.0 pueden mostrar 0 hits si el campo no se guardó
 - El módulo usa `COALESCE(hits, 1)` para contarlos como mínimo 1
 - Los nuevos registros siempre guardan hits correctamente
-

9. Changelog

v1.2.2 — 2026-03-26

- Revisión de umbrales: bots con ≥ 3 hits, IPs con ≥ 5 hits
- Mejora visual: los registros ya bloqueados aparecen en rojo en las tablas
- Checkbox deshabilitado para entradas ya bloqueadas
- Indicador de IP + país en la columna "Bot / IA Name"

v1.2.1 — 2026-03-26

- Corrección: `user_agent` ahora se guarda en INSERT y UPDATE de `recordAccess()`
- Corrección: `hits` se inserta explícitamente con valor `1` (evita registros con 0 hits)
- Queries con `COALESCE(hits, 1)` para compatibilidad con datos anteriores
- Filtro `HAVING` para mostrar solo IPs/UAs con actividad relevante

v1.2.0 — 2026-03-26

- **NUEVO:** Textarea  Bots Bloqueados (User-Agent) en configuración
- **NUEVO:** Textarea  IPs Bloqueadas en configuración
- **NUEVO:** Panel *Estadísticas Bots & IPs* con tablas interactivas debajo de la configuración
- **NUEVO:** Botón "BLOQUEAR Bots Seleccionados" — añade UAs a la lista negra con un clic
- **NUEVO:** Botón "BLOQUEAR IPs Seleccionadas" — añade IPs a la lista negra con un clic
- **NUEVO:** Detección automática de nombre y tipo de bot desde el User-Agent (50+ patrones)
- **NUEVO:** Bloqueo HTTP 403 por User-Agent en tiempo real (antes del geo-bloqueo)
- **NUEVO:** Bloqueo HTTP 403 por IP manual (antes del geo-bloqueo)
- Entradas bloqueadas marcadas visualmente en rojo en las tablas
- Versión del módulo actualizada a 1.2.0

v1.1.1 — anterior

- Geobloqueo por país con lista de países permitidos
- Lista blanca de IPs
- Logging de tráfico con agrupación por ventana de 1 hora
- Detección de frecuencia ($\text{avg_interval} < 2s \rightarrow \text{is_bot}$)
- Recálculo de países y herramientas de mantenimiento de base de datos
- Descarga de DB GeoIP masiva desde GitHub

10. Soporte

Email: ecomyse@gmail.com **Módulo:** GravityShield by Ecom Experts **Licencia:** Academic Free License (AFL 3.0)

Novedades de la versión 1.6.0

La "Fase 0" ahora funciona de verdad

La Fase 0 es el escudo que bloquea el tráfico basura **antes** de que PrestaShop arranque: antes de cargar la configuración, las librerías y antes de conectar con la base de datos. Un bot bloqueado en Fase 0 consume prácticamente cero recursos.

Hasta la versión 1.5.0 el enganche se escribía en un fichero que PrestaShop no carga nunca, así que la Fase 0 **no llegaba a ejecutarse**: todo el bloqueo se hacía después, con la tienda ya arrancada. Ya está corregido.

Qué tienes que hacer: entra en la configuración del módulo y pulsa **Guardar**. Eso inyecta el enganche y genera el escudo.

Cómo comprobarlo: en el panel *Mantenimiento y Logs* aparece una línea nueva, **Fase 0 (arranque del core)**:

Aviso	Significado
● Activa	Funcionando. El tráfico bloqueado ya no arranca PrestaShop.
● Enganchada y en modo inactivo	Todo correcto, pero no hay IPs ni bots bloqueados (o el modo pánico está activo). Coste cero.
● NO enganchada	Guarda la configuración. Si persiste, tu carpeta <code>/config</code> no tiene permisos de escritura: pídeselos a tu hosting.

El módulo escribe un bloque delimitado dentro de `config/defines_custom.inc.php` y **respetar cualquier otro contenido** que ya hubiera en ese fichero. Al desinstalar el módulo, el bloque se retira solo.

Base de datos GeoIP mucho más ligera

La base de países pasa de un fichero JSON a un **índice binario**. Antes, cada visita de una IP nueva obligaba a cargar en memoria la base entera (podía superar los 300 MB por petición); con un ataque de muchas IPs distintas, eso tumbaba el servidor. Ahora la consulta lee unos pocos bytes del disco y no usa memoria apreciable.

Qué tienes que hacer: en *Mantenimiento y Logs*, pulsa **Descargar GeoIP Local**. Si el aviso dice "*Formato antiguo (JSON) detectado*", es exactamente eso lo que falta. Al terminar verás "*OK · N rangos · X MB · índice binario*".

Otras mejoras de rendimiento

- Las listas de IPs bloqueadas y de la whitelist se consultan de forma instantánea aunque tengan miles de entradas.
- Si no tienes ninguna IP ni ningún bot bloqueado, o activas el **modo pánico**, el escudo se desactiva solo y no cuesta nada.

- Los crons y scripts de línea de comandos ya no pasan por el escudo.
 - El registro de la Fase 0 anota como máximo una línea por IP cada 60 segundos, para que un ataque no llene el disco de logs.
-

Novedades de la versión 1.7.0 — rendimiento

Esta versión no añade funciones nuevas: quita trabajo. Todo lo de abajo se aplica solo, sin que tengas que configurar nada.

Tu tienda (front)

- Las listas de IPs y de bots bloqueados se consultan al instante aunque tengan miles de entradas, en lugar de recorrerlas enteras en cada visita.
- La lista de bots de IA (que puede traer más de mil patrones) ya no se procesa en cada visita.
- Un ataque desde una misma IP genera como mucho un apunte cada 10 segundos, en vez de reescribir el registro en cada petición.
- El endpoint de métricas ya no monta la plantilla completa de la tienda solo para devolver cuatro números.

El panel de administración

Aquí está la mejora más grande. Abrir la configuración o el listado de logs lanzaba **más de cien consultas**, muchas recorriendo la tabla entera y bloqueándola mientras la tienda intentaba escribir en ella. Por eso la web podía notarse lenta justo cuando estabas mirando los logs. Ahora:

- El gráfico de actividad pasa de hasta **60 consultas** a **1**.
- El desglose por tipo de visitante y el de navegadores pasan de 5 consultas pesadas a 2 ligeras.
- El monitor en tiempo real hace **una** consulta por sondeo en lugar de dos, y guarda el resultado 2 segundos: tener dos pestañas abiertas ya no duplica la carga.
- Las tareas de migración se ejecutan **una sola vez**, no cada vez que abres la configuración.
- La limpieza automática (retención, rotación de ficheros) se hace **una vez por hora**. Si la quieres ahora mismo, tienes el botón nuevo **Forzar mantenimiento** en *Mantenimiento y Logs*.

Base de datos

Se han eliminado dos índices de la tabla de logs que ninguna pantalla usaba pero que había que actualizar en cada visita registrada, y se ha añadido uno que faltaba para ordenar el listado. Resultado: se escribe más rápido y el listado se abre más rápido. El cambio se aplica solo la primera vez que entres en la configuración tras subir esta versión.

Si "Descargar GeolP Local" da error

La dirección desde la que el módulo descargaba la base de países cambió de nombre en su origen y devolvía "no encontrado". El síntoma era este mensaje:

Descarga muy pequeña (14 bytes), probablemente bloqueada por firewall o redirección.

Esos 14 bytes eran literalmente el texto `404: Not Found`. Ya está corregido: el módulo usa la dirección nueva y, si fallara, prueba una segunda fuente automáticamente.

Además, ahora los errores dicen la verdad. Si algo falla verás exactamente qué, por ejemplo:

- `dbip-country-ipv4.csv -> HTTP 404` — el fichero ya no está en el origen.
- `dbip-country-ipv4.csv -> cURL: SSL certificate problem...` — tu servidor no tiene los certificados raíz configurados; pídeselo a tu hosting.
- `dbip-country-ipv4.csv -> solo 512 bytes` — algo (firewall, proxy) está cortando la descarga.

Al terminar bien verás: **OK · 358.140 rangos · 3,4 MB · índice binario.**

Si tu módulo de seguridad avisa de cambios en `config/`

"Fichero eliminado: `config/early_injection.php`" (severidad alta)

Lo hizo Ecom Shield, a propósito y una sola vez: era un fichero de una versión anterior del propio módulo que PrestaShop **no carga nunca**. Puedes marcar el aviso como revisado sin más.

A partir de esta versión el módulo **ya no borra nada** fuera de su propia carpeta. Si ese fichero existe, lo deja donde está y te lo indica en el panel *Mantenimiento y Logs* para que decidas tú.

"Fichero modificado: `config/defines_custom.inc.php`"

Antes, ese fichero se reescribía cada vez que abrías la configuración del módulo, aunque no hubieras cambiado nada, y tu vigilante lo marcaba una y otra vez.

Ya no: el módulo compara antes de escribir y solo toca el fichero si de verdad cambia algo (por ejemplo, si añades una IP a la lista de bloqueo). Si no cambias nada, ni siquiera se modifica la fecha del fichero.

Ese fichero **es** parte del funcionamiento de Ecom Shield: contiene el bloque delimitado que activa la Fase 0 en el arranque de PrestaShop. Es esperado que aparezca la primera vez y cada vez que cambies las listas de bloqueo.

Guía de Usuario - Ecom Shield

1. Instalación y Puesta en Marcha

Una vez instalado, el módulo activa automáticamente la protección. No se requiere configuración adicional para empezar a bloquear.

2. Configuración Principal

- **Whitelist IPs:** Pon aquí tu propia dirección IP para evitar quedarte bloqueado accidentalmente por ráfagas de visitas rápidas.
- **Lista Blanca SEO:** El sistema protege por defecto a Google y Bing para que no pierdas indexación ni visitas.
- **Bloqueo por Países (Geo-Blocking):** Actívalo solo si tu tienda vende en regiones específicas (ej: solo Europa).
- **Control de Bots Maliciosos:** Añade el nombre de los bots que no desees que vean tu tienda (ej: SemrushBot, AhrefsBot).

3. Registros de Seguridad (Logs)

En el menú **Parámetros Avanzados > GravityShield Logs** podrás ver: - Las IPs bloqueadas y cuántas veces han intentado entrar (**Hits**). - El **País** de procedencia. - El **Motivo** exacto por el que se ha denegado el acceso. - Si se detectó como un **Bot malicioso**.

4. Mantenimiento

Te recomendamos entrar una vez a la semana a "Limpiar Ruido" para borrar registros de 1 solo hit y dejar el historial limpio con los datos verdaderamente importantes de atacantes recurrentes.

GravityShield (ecom_shield) - Technical Documentation

Overview

GravityShield is a security module designed to protect PrestaShop stores from automated bot traffic during registration and login processes. It employs passive defense mechanisms like honeypots and time-traps to identify and block or log suspicious activity.

Architecture

- **Module Name:** `ecom_shield`
- **Class Name:** `Ecom_Shield`
- **Compatibility:** PrestaShop 8.0.0 - 9.99.99
- **License:** AFL 3.0

Key Components

1. Persistent Logging (Database)

The module maintains its own log table for detailed traffic analysis. - **Table:** `ps_ecom_shield_log` - **Fields:** - `id_ecom_shield_log` : Primary key. - `ip` : Visitor IP address. - `user_agent` : Visitor browser signature. - `is_bot` : Boolean flag for known bot signatures. - `context` : Action context (page_view, login, registration). - `reason` : Explanation of the action or detection. - `blocked` : Whether the action was actively blocked. - `request_uri` : The last URL visited by this IP in this context. - `hits` : Counter of total accesses for this IP/context. - `avg_interval` : Average time in seconds between hits. - `date_add` : Creation of the log entry. - `date_upd` : Last update (last hit) of the entry.

2. Back Office Controller

A dedicated administration page provides a real-time list of all events. - **Controller:** `AdminEcomShieldLog` - **Location:** Security / Advanced Parameters -> GravityShield Logs.

3. Detection Mechanisms

- **Honeypot:** A hidden input field (`gs_trampa`) injected into forms. If filled, the request is flagged as a bot.
- **Time-Trap:** A timestamp (`gs_time`) encrypted with `Tools::encrypt()` . If the form is submitted faster than 3 seconds, it is flagged.
- **Whitelisting:**
- **Localhost:** requests from `127.0.0.1` or `::1` are ignored.
- **Admins:** Active employee sessions (Context employee) are ignored.
- **Search Bots:** User-Agent check for major crawlers (Google, Bing, Baidu, Yandex).

- **Frequency Analysis:** If an##  Arquitectura Fase-0 (Early Injection) La protección Fase-0 se inyecta en `config/early_injection.php` y se ejecuta antes de cargar el núcleo de PrestaShop.

Mejoras de Seguridad y Rendimiento

- **Seguridad (var_export):** Los datos del administrador ya no se inyectan con `addslashes`, sino mediante `var_export()` para prevenir inyecciones de código PHP en el script de bloqueo.
- **Rendimiento (Regex Único):** En lugar de iterar sobre una lista de patrones, Fase-0 compila todos los bots bloqueados en una única expresión regular de alta velocidad.
- **Observabilidad:** Los bloqueos de Fase-0 se registran en `logs/phase0.log` y se sincronizan con la base de datos automáticamente.



Observabilidad y Métricas

El módulo expone un endpoint JSON para integración con sistemas externos (Grafana/Prometheus). - **Ruta:**

`index.php?fc=module&module=ecom_shield&controller=metrics&token=[ENCRYPTED_TOKEN]` - **Métricas:** Hits totales, bloqueos, tasa de rebote y Top 5 países.



Multi-fuente IA

La lista de bots de IA ahora soporta múltiples URLs separadas por comas.

4. Gmartos Connect Integration

Automatic registration and version checking via `https://modules.gmartos.es/api.php`.

Hooks Used

- **actionDispatcher:** Used for global traffic logging and early auth validation.
- **displayCustomerAccountFormTop:** Injects hidden trap fields into the registration form.
- **displayCustomerLoginFormAfter:** Injects hidden trap fields into the login form.
- **actionSubmitAccountBefore:** Validates registration attempts.

Configuration Modes

- **Simulation (Dry Run):** Logs detections but allows actions.
- **Active Block:** Actively stops suspicious requests.

Fase 0 — enganche real en el arranque del core (v1.6.0)

Punto de inyección

`config/config.inc.php` de PrestaShop 8/9 empieza así:

```
if (is_file(__DIR__ . '/defines_custom.inc.php')) {
    include_once __DIR__ . '/defines_custom.inc.php';
}
require_once __DIR__ . '/defines.inc.php';
require_once _PS_CONFIG_DIR_ . 'autoload.php'; // aquí se define _PS_VERSION_
...
require_once __DIR__ . '/bootstrap.php'; // Doctrine / Symfony / MySQL
```

`config/defines_custom.inc.php` es la **primera** instrucción del arranque: se ejecuta antes de `defines.inc.php`, del autoload de Composer, del kernel de Symfony y de la conexión a MySQL. Es el único punto legítimo para cortar tráfico sin pagar el arranque completo de la tienda.

`installEarlyInjection()` escribe ahí un bloque delimitado:

```
/* ecom_shield:early:start - NO EDITAR */
$ecs_early = __DIR__ . '/../modules/ecom_shield/ecom_shield_early.php';
if (@is_file($ecs_early)) { include_once $ecs_early; }
unset($ecs_early);
/* ecom_shield:early:end */
```

- Idempotente: reescribe solo su bloque, respeta el resto del fichero del cliente.
- `removeEarlyInjection()` (llamado en `uninstall()`) retira solo el bloque; si el fichero quedaba vacío, lo borra.
- Ruta relativa a `__DIR__` cuando el directorio de módulos es el estándar, de modo que el enganche sobrevive a migraciones de servidor.

Regresión corregida: hasta 1.5.0 el bloque se escribía en `config/early_injection.php`, un fichero que el core **nunca** carga. La Fase 0 no llegaba a ejecutarse jamás y todo el bloqueo recaía en los hooks `actionDispatcher / actionFrontControllerInit`, es decir, después del arranque completo. `installEarlyInjection()` borra ese huérfano si lo encuentra.

Script generado (`ecom_shield_early.php`)

`createEarlyScript()` compila la configuración a PHP plano. Orden de evaluación, del más barato al más caro:

1. `defined('_PS_VERSION_') || PHP_SAPI === 'cli' → return` (CLI y crons intactos).
2. Resolución de IP (`CF-Connecting-IP` → `X-Forwarded-For` → `REMOTE_ADDR`).
3. Salida inmediata para `127.0.0.1 / ::1`.
4. Bots SEO legítimos: **un** `preg_match` (antes: 7 `stripes` encadenados).

5. Whitelist exacta: `isset($ecs_wl[$ip])` → **O(1)** (antes: `in_array()` O(n)).
6. Whitelist CIDR (solo se emite si hay entradas con `/`).
7. Blacklist exacta O(1) + CIDR, y regex de bots.

Optimizaciones de generación:

Situación	Fichero generado
Sin IPs ni bots bloqueados	<code>stub: return; /* sin reglas activas */</code>
<code>GRAVITY_PANIC</code> o <code>KILL_SWITCH</code>	<code>stub: return; /* modo panico activo */</code>
Sin entradas CIDR	no se emite <code>ecs_p0_cidr()</code>

- `ecs_p0_cidr()` y `ecs_p0_log()` son **funciones declaradas**, no closures: el tráfico que pasa no paga ni la asignación del objeto `Closure`.
- El log usa `__DIR__ . '/logs/phase0.log'` (relocalizable). Anti-amplificación: máximo una línea por IP cada 60 s (APCu o marca en `sys_get_temp_dir()`).
- Escritura atómica (`writeEarlyFile()` : tmp + `rename()` + `opcache_invalidate()`) para que ninguna petición incluya un fichero a medio escribir.
- `getEarlyInjectionStatus()` alimenta el aviso del panel de mantenimiento (no enganchada / enganchada inactiva / activa).

GeoIP: índice binario `data/ip_ranges.bin` (v1.6.0)

Formato

```
offset 0   : 8 bytes  MAGIC "ECSGE01\0"
offset 8+  : registros de 10 bytes, ordenados ascendente por IP inicial
              uint32 BE inicio | uint32 BE fin | 2 bytes ISO-3166
```

```
n_registros = (filesize - 8) / 10
```

Por qué

`GeoLite::getCountry()` hacía `file_get_contents()` + `json_decode()` de `data/ip_ranges.json` **completo**. Con la fuente real (dbip-country, ~500.000 rangos) eso son 20–30 MB de JSON que se expanden a **300–500 MB** de arrays PHP, y ocurría en **cada petición con IP no cacheada**. Un flood de IPs únicas agota el pool de PHP-FPM antes de que el geobloqueo llegue a decidir nada.

Ahora la búsqueda binaria se hace con `fseek()` / `fread()` sobre el fichero: ~19 lecturas de 10 bytes y ~0 bytes de RAM, con el handle reutilizado durante toda la petición.

Construcción

`downloadGeoDB()` es 100 % streaming: el CSV va a fichero temporal vía `CURLOPT_FILE` y se recorre con `fgets()`, empaquetando a un buffer de 64 KB. Nunca se materializa el CSV ni un array de 500.000 elementos. Si la fuente llegara desordenada, `sortBinaryIndex()` reordena (los registros big-endian ordenan igual como cadena que como entero, así que basta `sort($records, SORT_STRING)`).

Compatibilidad

- `GeoLite::lookupJson()` sigue existiendo como fallback, **con tope de 6 MB** (`JSON_MAX_BYTES`). Por encima no se carga: devolver país desconocido es preferible a reventar la memoria del pool — y el módulo nunca bloquea con país desconocido.
- `migrateGeoDbToBinary()` convierte un `ip_ranges.json` heredado al índice binario y lo borra. Se ejecuta desde `addNewFeatures()`, es decir, solo al entrar en la configuración: **jamás** en el path de petición.

API de `GeoLite`

Método	Uso
<code>getCountry(\$ip)</code>	ISO-3166 o <code>false</code> . Memoiza por petición.
<code>packRecord(\$start, \$end, \$cc)</code>	Serializa un registro de 10 bytes.
<code>countRecords()</code>	Nº de rangos del índice.
<code>resetCache()</code>	Invalida estáticos tras regenerar el índice.
<code>binPath()</code> / <code>jsonPath()</code>	Rutas de los ficheros de datos.

Optimización del path caliente y del back-office (v1.7.0)

Coste por petición de front

Punto	Antes	Ahora
Bots SEO legítimos	7 × <code>stripes()</code>	1 × <code>preg_match (LEGIT_BOTS_RE)</code>
Whitelist / blacklist de IPs	<code>preg_split()</code> del texto de config + recorrido O(n) de todas las entradas	<code>prepareIpList()</code> : mapa <code>isset()</code> O(1) + solo los CIDR se recorren. Memo por petición y APCu 1 h con clave = hash del contenido
Bots por User-Agent	bucle de N <code>stripes()</code>	<code>prepareBotRegex()</code> : una regex compilada y cacheada
Lista IA (<code>ai.robots.txt</code> , >1000 patrones)	<code>preg_split()</code> + hasta N <code>stripes()</code> en cada <code>detectBotInfo()</code>	<code>getAiRobotsRegex()</code> : una regex cacheada + memo de <code>detectBotInfo()</code> por UA
Hit bloqueado con APCu	read-modify-write del buffer transitorio entero (300 entradas serializadas) en cada petición	contador atómico <code>apcu_inc</code> O(1) por IP + volcado al buffer una vez cada 10 s
<code>isDiskCritical()</code> sin APCu	2 × <code>statfs</code> por petición	1 × <code>stat</code> sobre fichero de marca (TTL 30 s)

Las claves de caché usan el **hash del contenido** de la configuración (`ecs_1st_<md5>` , `ecs_botre_<md5>` , `ecs_aire_<md5>`), de modo que un cambio en el back-office produce una clave nueva: no hay invalidación que orquestar ni riesgo de servir listas obsoletas.

`ipMatchesList()` se ha eliminado; lo sustituyen `prepareIpList()` + `ipMatchesPrepared()` . La equivalencia de comportamiento (IP exacta, CIDR IPv4 e IPv6, no-coincidencia) está cubierta por pruebas.

`recordBlockedFast()` — la inversión que había

El dedup por IP solo se aplicaba **cuando NO había APCu**, justo al revés de lo conveniente: con APCu, `pushBlockedTransient()` hace un read-modify-write del buffer completo. Bajo flood era el mayor coste del módulo y además perdía entradas por carrera entre procesos. Ahora el dedup de 10 s se aplica en ambos caminos.

`getMetrics()` — no había caché sin APCu

El endpoint se sondea ~1 vez/segundo y lanzaba **3 agregaciones full-table** por sondeo, compitiendo con los INSERT del front sobre la misma tabla. Ahora: respaldo en fichero (`logs/metrics_cache.json` , TTL 10 s) cuando no hay APCu, y los dos `SUM()` fusionados en una sola pasada con `CASE WHEN` .

`controllers/front/metrics.php`

Se responde en `init()` (igual que el controlador de captcha) y el token se valida **antes** de montar nada. La versión anterior llamaba a `parent::initContent()` primero, es decir, construía el contexto completo de front

(Smarty, header, footer) para un endpoint JSON —y también para peticiones no autorizadas. La comparación del token usa `hash_equals()`.

Migraciones: una vez por versión, no en cada carga

`addNewFeatures()` se invoca desde `getContent()`, así que **cada** visita a la configuración ejecutaba `migrateExistingLogs()`: ~56 `UPDATE ... WHERE user_agent LIKE "%x%" OR reason LIKE "%x%"` sobre columnas `TEXT`. Un comodín inicial impide usar índices, así que eran 56 escaneos completos **con bloqueos de escritura** sobre la tabla en la que el front está insertando.

Ahora el bloque DDL + migración se guarda tras `GRAVITY_SCHEMA_VERSION` (constante `SCHEMA_VERSION`). Para forzar una nueva migración en el futuro basta con incrementar la constante.

`enforceLogLimits($force = false)` se limita a **una pasada por hora** (`GRAVITY_LAST_MAINTENANCE`); el botón *Forzar mantenimiento* del panel la ejecuta bajo demanda.

Índices de `ecom_shield_log`

Índice	Acción	Motivo
<code>agg_index</code> (ip, blocked, context, ua(64))	se mantiene	lo necesita el <code>INSERT ... ON DUPLICATE KEY UPDATE</code>
<code>idx_visitor_type</code>	se mantiene	usado por el reparto por tipo
<code>idx_date_upd</code>	se mantiene	rango temporal de todas las estadísticas
<code>idx_date_add</code>	añadido	es el <code>ORDER BY</code> por defecto del listado; sin él, filesort de la tabla entera en cada carga
<code>perf_index</code> (ua(64), ip)	eliminado	ninguna consulta del módulo lo usa; encarece cada INSERT con un prefijo de 64 bytes
<code>hits</code>	eliminado	<code>hits</code> se incrementa en cada hit repetido, así que la entrada del índice se reubica en cada escritura: el índice más caro posible sobre la tabla más caliente

Consultas del back-office

Bloque	Antes	Ahora
Gráfico temporal	bucle de 24 o 30 iteraciones × 2 consultas = hasta 60 , y en modo diario con <code>WHERE DATE(date_upd) = "..."</code> (función sobre la columna indexada, escaneo completo cada una)	1 consulta con rango sobre <code>idx_date_upd + GROUP BY</code> ; el relleno de cubos vacíos se hace en PHP
Cabecera (hits / bloqueados / IPs únicas)	3 consultas	1
Reparto por tipo de visitante	4 <code>SUM()</code>	1 <code>GROUP BY visitor_type</code>
Navegadores	<code>GROUP BY user_agent</code> sobre columna <code>TEXT</code> (tabla temporal en disco) y una fila por UA distinto traída a PHP	1 consulta con <code>SUM(CASE ...)</code> que devuelve 4 números
Monitor en tiempo real	2 consultas por sondeo, 1 sondeo/segundo, sin caché	1 consulta (<code>NOW()</code> incluido en el <code>SELECT</code>) + caché APCu de 2 s

El `LIKE` de la agregación de navegadores es *case-insensitive* por la collation de la tabla, igual que el `strtolower()` que hacía el bucle PHP anterior; la equivalencia está cubierta por pruebas.

Recuento de hits bloqueados: el dedup limita escrituras, no cuentas

Deduplicar sin más habría hecho que el monitor mostrase 1 hit por IP cada 10 s en lugar del volumen real del ataque. Por eso `recordBlockedFast()` mantiene dos claves APCu por IP:

- `ecs_blkx_md5(ip)>` — contador atómico (`apcu_inc`, una sola clave entera, sin serializar nada). Se incrementa en **todas** las peticiones.
- `ecs_blkx_md5(ip)>` — marca de ventana (TTL 10 s). Mientras exista, no se escribe en el buffer agregado.

Al cerrar la ventana, la primera petición vuelca el contador acumulado vía `pushBlockedTransient(..., $hits)` y lo borra. Consecuencias:

- el recuento del monitor es **exacto**;
- las escrituras caras (serializar el buffer de 300 entradas) bajan a 1 por IP cada 10 s — medido: 300 hits → 3 escrituras;
- el contador se crea **siempre con TTL**, así que una IP que deje de atacar a mitad de ventana no deja una clave huérfana;
- queda una cola de hasta 10 s sin volcar si el ataque cesa. Es un monitor en vivo, no contabilidad: se asume.

Sin APCu no hay contador atómico barato y se mantiene el comportamiento histórico (1 apunte por IP cada 10 s).

Caché del monitor y el reloj

El payload cacheado 2 s incluye `server_time`, que la interfaz pinta como reloj. Servirlo tal cual lo congelaría y daría saltos de 2 s: el usuario leería que el monitor está colgado. Al servir desde caché se reajusta la hora sumando los segundos transcurridos (`strtotime` + `date`), de modo que el reloj sigue corriendo. Cruce de medianoche y deriva negativa del reloj del sistema están cubiertos por pruebas.

Cuando la consulta no devuelve filas, `server_time` se pide a MySQL con una consulta suelta —**no** se usa `date()` de PHP—: `date_upd` se escribe con `NOW()` y PHP puede estar en otra zona horaria.

Etiquetas de motivo normalizadas

Las regex de bots son *case-insensitive*, así que el texto que casa puede venir con otras mayúsculas que el patrón configurado. Sin normalizar, `Bot: AhrefsBot` y `Bot: ahrefsbot` cuentan como motivos distintos en el `GROUP BY reason` del panel. `canonicalPattern()` devuelve el patrón tal y como está escrito en la configuración. Se aplica tanto a bots bloqueados como a los SEO legítimos.

Lista de bots SEO unificada

`LEGIT_BOTS` / `LEGIT_BOTS_RE` son ahora la única fuente para la Fase 0 y para `logTraffic()`. Antes divergían: la Fase 0 aceptaba `InspectionTool` a secas y `logTraffic()` solo `Google-InspectionTool`, de modo que un mismo bot podía pasar la Fase 0 y ser evaluado de otra forma después.

Robustez del índice binario

Caché de `stat` de PHP

`filesize()` está cacheada por PHP durante la petición. Al regenerar `ip_ranges.bin`, `openIndex()` leería el tamaño **anterior**: el número de registros saldría mal, la búsqueda binaria saltaría más allá del final del fichero y **todas** las IPs quedarían sin país durante el resto de la petición, en silencio. Por eso `openIndex()` y `getGeoDbStatus()` llaman a `clearstatcache(true, $path)` antes de medir. `openIndex()` corre como mucho una vez por petición, así que no tiene coste apreciable.

Reproducido y cubierto por pruebas: con el índice reducido en la misma petición, sin `clearstatcache()` el lookup devuelve `false`; con él, el país correcto.

Empaquetado seguro en PHP de 32 bits

`packRecord()` **no** usa `pack('N', (int) $valor)`. En PHP de 32 bits el cast a `int` de un float por encima de 2^{31} —o sea, de la IP `128.0.0.0` en adelante— tiene resultado indefinido y produciría un índice corrupto para media Internet. `uint32be()` construye los cuatro bytes en coma flotante, correcto en 32 y 64 bits. Verificado byte a byte contra `pack('NN')` en todo el rango, y con un recorrido de los 256 bloques `/8` del espacio IPv4.

Parseo del CSV

`downloadGeoDB()` usa `explode(',', $line)` en lugar de `str_getcsv()`:

- la fuente es `inicio,fin,ISO` sin comillas ni escapes;
- es notablemente más rápido sobre 500.000 líneas;
- evita la deprecación de `str_getcsv()` sin `$escape` en PHP 8.4, que si no emitiría un aviso **por cada línea**.

Las filas cuyos dos primeros campos no son numéricos (cabeceras, líneas corruptas) se descartan sin abortar la importación.

Otras salvaguardas

- **Migración con tabla grande.** El bloque DDL + migración hace `set_time_limit(0)` e `ignore_user_abort(true)`. Sin ello, en una tabla con histórico el `ALTER` podía superar el `max_execution_time`; como `GRAVITY_SCHEMA_VERSION` se marca *después*, el siguiente acceso reintentaría: bucle de timeouts en el back-office.
- **Modo auditoría en el panel.** `getEarlyInjectionStatus()` distingue si el script de Fase 0 corta o solo registra (busca el `exit('403')`), para no anunciar que se está bloqueando cuando en realidad pasa todo.
- **Directorios `logs/` y `data/`.** `initializeFolders()` deja en cada uno un `.htaccess` de denegación y un `index.php`. Guardan logs de accesos e IPs: el `.htaccess` del módulo solo desactivaba el listado de directorio.
- `idx_date_upd`. En instalaciones existentes el índice se llama `date_upd` (nombre automático de MySQL). `addNewFeatures()` **no** lo vuelve a crear: `ADD INDEX IF NOT EXISTS` compara por NOMBRE, no por columnas, y se crearía un índice duplicado que encarecería cada escritura.
- `sql_mode`. PrestaShop hace `SET SESSION sql_mode = ''` al conectar (`DbPDO / DbMySQLi`), así que las consultas del panel con `GROUP BY` no chocan con `ONLY_FULL_GROUP_BY`.

Origen de la base GeolP (corregido)

La URL que usaba el módulo dejó de existir:

```
https://raw.githubusercontent.com/sapics/ip-location-db/main/
dbip-country/dbip-country-ipv4-num.csv -> HTTP 404
```

El repositorio retiró la variante `-num`. El cuerpo del 404 de `raw.githubusercontent.com` es la cadena `404: Not Found`, **14 bytes**, que `curl_exec()` con `CURLOPT_FILE` escribía en el fichero devolviendo `true` (la transferencia sí tuvo éxito). Como el código comprobaba el tamaño antes que el código HTTP, el mensaje resultante era *"Descarga muy pequeña (14 bytes)"* y ocultaba el 404.

Cambios

1. **Fuentes con reserva.** Se prueban en orden y la primera que responda 200 con tamaño suficiente gana: - `dbip-country/dbip-country-ipv4.csv` - `geolite2-country/geolite2-country-ipv4.csv`

2. **Diagnóstico primero el HTTP.** El orden de comprobación es `cURL` → `HTTP != 200` → tamaño. El error acumula lo que falló en cada fuente, p. ej.: `dbip-country-ipv4.csv -> HTTP 404` | `geolite2-country-ipv4.csv -> HTTP 404`.
3. **Los dos formatos de CSV.** `csvIpToLong()` acepta tanto el numérico (`16777216,16777471,AU` , formato antiguo) como el de IPs con puntos (`1.0.0.0,1.0.0.255,AU` , formato actual). Las líneas que no encajan en ninguno —cabeceras, basura— se descartan sin abortar la importación.

Importación real medida

Rangos importados	358.140
Índice generado	3,4 MB
Tiempo total (descarga + conversión)	2,6 s
RAM pico durante la importación	2,0 MB

Comprobación de países con IPs conocidas: `8.8.8.8` →US, `208.67.222.222` →US, `80.58.61.250` →ES, `212.230.0.1` →ES, `77.88.8.8` →RU, `223.5.5.5` →CN, `1.1.1.1` →AU (correcto: el bloque `1.1.1.0/24` está registrado a APNIC/Australia aunque Cloudflare lo anuncie desde todo el mundo).

Convivencia con módulos de integridad de ficheros

Un vigilante de integridad reporta cualquier alta, baja o modificación en `config/`. El módulo tocaba ese directorio más de la cuenta:

Comportamiento anterior	Aviso que generaba
Borrar <code>config/early_injection.php</code> (huérfano de versiones previas)	<i>Fichero eliminado — severidad alta</i>
Reescribir <code>config/defines_custom.inc.php</code> en cada carga de la configuración (<code>getContent()</code> → <code>addNewFeatures()</code> → <code>installEarlyInjection()</code>)	<i>Fichero modificado, de forma recurrente</i>
Reescribir <code>ecom_shield_early.php</code> en cada carga	ídem

Reglas actuales

1. **El módulo no borra ningún fichero fuera de su propio directorio.** El `config/early_injection.php` heredado se deja donde está —PrestaShop no lo carga nunca, es inerte— y el panel avisa de que existe para que lo elimine el administrador si quiere.
2. **Escritura solo si el contenido cambia.** `installEarlyInjection()` y `writeEarlyFile()` comparan el contenido generado con el que ya hay en disco y salen sin tocar nada si coinciden. Ni la fecha de modificación cambia.

Cubierto por pruebas: tras retrasar artificialmente la fecha de los dos ficheros, tres pasadas de `installEarlyInjection()` no alteran ni el `mtime` ni el hash; al cambiar la lista de IPs bloqueadas, el script sí se regenera.

Documentación Técnica - Ecom Shield

1. Arquitectura de Seguridad

El módulo implementa un sistema de seguridad en tres anillos: - **Anillo 0 (Fase 0):** Inyección temprana mediante `config/early_injection.php`. Bloquea IPs y Bots antes de que se inicie PrestaShop, la Base de Datos o la Caché. - **Anillo 1 (Dispatcher):** Interceptación en el hook `actionDispatcher` para tráfico de Front-Office. - **Anillo 2 (GeoIP/UA):** Validación de país y patrones de User-Agent.

2. Base de Datos

Tabla principal: `ps_ecom_shield_log` - Usa índices únicos (`ip`, `blocked`, `context`) para permitir el conteo de hits mediante `ON DUPLICATE KEY UPDATE`. - **Nuevo:** Clasificación de tráfico (`visitor_type`) en categorías: `Legitimos`, `Crawlers`, `Scrapers`, `IA`, `Monitor`, `Social`. - Las columnas críticas son `country_code`, `request_uri`, `context` y `visitor_type`.

3. Dashboard Administrativo

- **Dashboard Premium:** Visualización avanzada con Chart.js.
- **Gráficos:** Evolución temporal de Hits y Bloqueos, y distribución por tipo de visita (Donut Chart).
- **Filtrado:** Soporte para periodos (Hoy, 7 días, 30 días).

3. Logs y Sincronización

Debido a que la Fase 0 no puede conectar con la base de datos de PrestaShop (por rendimiento), los bloqueos se escriben en `/logs/phase0.log` en formato JSON. El módulo vuelca estos logs a la DB al entrar en el Administrador o en cada visita al Front de forma asíncrona.

4. Requisitos y Compatibilidad

- PrestaShop 1.7+ / 8.x
- PHP 7.4+
- Acceso de escritura en `/config/early_injection.php` y `/modules/ecom_shield/logs/`
- **Traducciones:** Implementa `isUsingNewTranslationSystem()` para plena compatibilidad con PrestaShop 8.
- **Legacy Controller:** Soporte para métodos `1()` en controladores heredados para evitar errores en el router de Symfony.

GravityShield Developer Guide

Modifying Logic

This module logic is centralized in `Ecom_Shield::validateBotTraffic($contextType)`. You can override this method by creating an override in `override/modules/ecom_shield/ecom_shield.php`.

Whitelist Customization

To add specific IPs or User-Agents: 1. **Whitelisting is hardcoded:** For security, whitelisting logic is within `validateBotTraffic`. - Example: `if ($ip === '1.2.3.4') return;` 2. **User-Agents:** A standard regex is used. Modify the regex `/Googlebot|Bingbot|DuckDuckBot/i` to add more bots.

Testing & Validation

- **Localhost Testing:** Use `127.0.0.1` or `::1` for testing. The module ignores these IPs by default.
- **Force Testing:** Check logs in `Advanced Parameters > Logs`. In `validateBotTraffic`, comment out the whitelist logic temporarily if needed.

Configuration & Logs

- **Logs:** Located in `Ps_Log` table.
- **Config:** `GRAVITY_BLOCK_MODE` (bool).
- `0` = Simulation (Logger Only)
- `1` = Active Blocking (Stop Action)

Files Structure

- `ecom_shield.php` : Main module file.
- `docs/` : Documentation.
- `index.php` : Security header.

Contributing

- Follow strict PrestaShop coding standards.
- Ensure all files have the correct License Header.
- Do NOT modify checks inside `hookActionDispatcher` unless necessary for initialization.

Guía Profesional de Desarrollo - Ecom Shield

1. Personalización de Ganchos (Hooks)

El módulo se ancla automáticamente al principio (`position = 1`) del hook `actionDispatcher` para tráfico de Front-Office. Si necesitas extender la seguridad a otros puntos del API, puedes usar el método `$this->logTraffic()` dentro de cualquier hook de PrestaShop.

2. Desarrollo de la Fase 0

El script `ecom_shield_early.php` se encuentra en el directorio raíz del módulo. Es un PHP nativo **totalmente autónomo** (sin PrestaShop cargado). No uses clases de PrestaShop dentro de este archivo si decides ampliarlo, ya que fallará el resto de la web.

3. Base de Datos Local GeolIP

Si decides usar la geolocalización avanzada por base de datos local, utiliza el archivo `classes/GeoLite.php` . Incluye un sistema de descarga masiva desde GitHub que convierte CSV a JSON para una latencia mínima de búsqueda binaria.

4. Sincronización de Hits

Utiliza siempre el método `recordAccess($context, $reason, $blocked, $country, $custom_ip)` . La clave única `ip_blocked_context` evitará que la tabla de logs crezca indefinidamente por duplicados, permitiendo que la columna `hits` incremente automáticamente.

5. Clasificación de Tráfico IA y Bots

El método `detectBotInfo($ua)` categoriza las visitas en 6 tipos principales: `Legitimos` , `Crawlers` , `Scrapers` , `IA` , `Monitor` y `Social` . Puedes extender estas categorías modificando los patrones regex en dicho método. Esta clasificación es fundamental para alimentar el dashboard administrativo.

6. Dashboard y Observabilidad

El controlador `AdminEcomShieldLog` utiliza **Chart.js v4** para renderizar métricas en tiempo real. Los datos se extraen mediante consultas agregadas que aprovechan el campo `visitor_type` . Se recomienda mantener los índices de la base de datos optimizados para asegurar que el renderizado de gráficos sea fluido incluso con miles de registros.

7. Estándares PrestaShop 8 y Traducciones

Para asegurar el funcionamiento óptimo en versiones modernas: - **Traducciones Modernas:** El módulo está registrado con `isUsingNewTranslationSystem()`. - **Compatibilidad del Controlador:** Se ha implementado un bypass para el método `1()` en el controlador administrativo, delegando al módulo para evitar fallos de métodos indefinidos durante el pre-renderizado de Symfony.

GravityShield - Professional Development Guide

Standards & Compatibility

- **PHP:** Must remain compatible with PHP 7.4 and 8.x.
- **Coding Styles:** Avoid `::class` syntax on objects; use `get_class($object)`.
- **Namespaces:** The main module file MUST NOT use namespaces to ensure compatibility with PrestaShop's legacy installer. Secondary classes in `/classes/` or `/src/` should be manually required.

Database Management

All logs are stored in the `ecom_shield_log` table. - Use the `ShieldLog` ObjectModel for all CRUD operations.
- Ensure `pSQL()` is used for any manual queries.

Admin Controller Implementation

The `AdminEcomShieldLogController` uses PrestaShop's `HelperList` to display logs. - Do not modify logs via the BO; the controller should be read-only (except for the delete action). - The controller is registered under the "Security" parent tab if available, falling back to "Advanced Parameters".

Hooks & Context

Avoid calling `Context::getContext()` inside Controllers. Use `$this->context`. In the main module class, use `Context::getContext()` with a leading backslash: `\Context::getContext()`.

Optimización de Logs y Agrupación de Tráfico

Para evitar la saturación de la base de datos con miles de entradas redundantes, se ha implementado: 1. **Agrupación por IP y Contexto:** El sistema busca registros existentes para la misma IP en la última hora y actualiza el contador de `hits` en lugar de insertar una nueva fila. 2. **Filtrado de Ruido Administrativo:** Se ha añadido un método `purgeNoise()` en el controlador para limpiar de un plumazo todos los registros de "1 solo hit" que no representan amenazas ni bloqueos. 3. **Análisis de Frecuencia:** El sistema calcula el `avg_interval` dinámicamente. Un intervalo `< 2s` con más de 3 hits marca automáticamente el registro como `is_bot`.

API Connectivity

The module connects to `modules.gmartos.es`. - **Frequency:** Once per week. - **Timeout:** Strict 3 seconds via cURL to avoid slowing down the store. - **Privacy:** Only sends the module version, shop URL, and public contact email.

Fase 0 y GeoIP — reglas de mantenimiento (desde v1.6.0)

Tocar `config/defines_custom.inc.php`

- **Nunca** reescribir el fichero entero: puede contener defines del cliente. Editar exclusivamente entre `EARLY_MARK_OPEN` y `EARLY_MARK_CLOSE` usando `stripEarlyBlock()`.
- `installEarlyInjection()` debe seguir siendo idempotente: N llamadas → 1 bloque.
- `removeEarlyInjection()` es **obligatorio** en `uninstall()`. Si se añade otra vía de desactivación, engancharlo también ahí.
- No usar constantes de PrestaShop dentro del script de Fase 0: en ese punto del arranque **no existe ninguna** (`_PS_MODULE_DIR_`, `_PS_VERSION_`, `_DB_PREFIX_`...). Solo `__DIR__`, `$_SERVER` y funciones nativas de PHP.

Escribir en `ecom_shield_early.php`

Ese fichero se ejecuta en el **100 %** de las peticiones de la tienda. Antes de añadir cualquier línea:

- Prohibido: acceso a BD, `Configuration::get()`, cURL, `json_decode` de ficheros grandes, `glob()`, `scandir()`, autoload de clases.
- Preferir `isset($map[$k])` a `in_array()`; un `preg_match` a N `stripos()`.
- Declarar helpers como funciones (`if (!function_exists(...))`), no como closures: la declaración no se ejecuta, la closure sí se instancia.
- Emitir código solo si hace falta (CIDR, logger). Si no hay reglas, generar stub.
- Escribir siempre con `writeEarlyFile()` (`tmp` + `rename()` + `opcache_invalidate()`).
- Rutas relativas a `__DIR__`, nunca absolutas de la máquina de desarrollo.

Tras cambiar el generador, verificar que la salida lintea: `C:\dev-tools\php\php-8.3\php.exe -l ecom_shield_early.php`

GeoIP

- El formato canónico es `data/ip_ranges.bin`. Cualquier lectura nueva debe pasar por `GeoLite::getCountry()`; no volver a `json_decode` del fichero completo.
- Si se cambia el formato del registro, subir el `MAGIC` (`ECSGE01\0` → `ECSGE02\0`): `openIndex()` rechaza los índices con firma distinta y el módulo degrada a "país desconocido" en lugar de leer basura.
- El país desconocido (`--`) **nunca** debe bloquear. Es la salvaguarda que evita cortar tráfico legítimo cuando la base de datos falta o está corrupta.
- `GeoLite::getCountryFromApi()` sigue existiendo pero está prohibida en el path de petición: 3 s de cURL por IP nueva agotan el pool de PHP-FPM.

Coste por petición: presupuesto

Etapa	Presupuesto
Fase 0 sin reglas	stub, ~0
Fase 0 con reglas, tráfico legítimo	1 <code>preg_match</code> + 1-2 <code>isset</code>
Geo lookup, IP nueva	~19 <code>fread</code> de 10 bytes
Geo lookup, IP repetida	APCu (1 h) o memo estático
Hit permitido	1 INSERT por IP/ventana (<code>GRAVITY_LOG_ALLOWED_WINDOW</code>)
Hit bloqueado	0 escrituras a MySQL (buffer transitorio)

Reglas de rendimiento añadidas en v1.7.0

Configuración leída en el path de petición

- Nunca hacer `preg_split()` de un valor de `Configuration` dentro de `logTraffic()`. Usar `prepareIpList()` / `prepareBotRegex()`, que memoizan por petición y cachean en APCu con clave = **hash del contenido**.
- Al añadir una lista nueva de configuración que se consulte por petición, seguir ese patrón: hash del texto como clave, TTL de 1 h, memo estático.
- Nunca recorrer una lista completa por petición si se puede indexar por clave.

Escrituras del buffer transitorio

- Todo camino que llame a `pushBlockedTransient()` debe pasar antes por el dedup de `recordBlockedFast()`. `pushBlockedTransient()` hace read-modify-write del buffer entero; sin dedup, un flood lo convierte en el cuello de botella.

Cachés

- Toda caché nueva necesita **los dos caminos**: APCu y respaldo en fichero. La mayoría de hostings compartidos no tienen APCu, y es justo donde más duele.
- Los endpoints sondeados (métricas, monitor) exigen caché con TTL mayor o igual al intervalo de sondeo. Sin ella, dos pestañas del back-office duplican la carga sobre la misma tabla que el front está escribiendo.

Migraciones y mantenimiento

- Nada que escanee la tabla puede colgar de `getContent()` sin puerta. El DDL y las migraciones van tras `GRAVITY_SCHEMA_VERSION`; el mantenimiento, tras `GRAVITY_LAST_MAINTENANCE` (1 pasada/hora, o `enforceLogLimits(true)`).
- Para forzar una migración nueva: incrementar `Ecom_Shield::SCHEMA_VERSION`.

SQL sobre `ecom_shield_log`

- **Prohibido** aplicar funciones a la columna filtrada: `WHERE DATE(date_upd) = x` anula `idx_date_upd`. Filtrar por rango (`date_upd >= "..."`) y, si hace falta, agrupar con `GROUP BY DATE(date_upd)`.
- **Prohibido** `GROUP BY user_agent / reason` (columnas `TEXT`): fuerza tabla temporal en disco. Agregar con `SUM(CASE WHEN ... LIKE ... THEN hits ELSE 0 END)`.
- **Prohibido** un bucle PHP que lance una consulta por cubo temporal. Una consulta agrupada y el relleno de huecos en PHP.
- Antes de añadir un índice, comprobar el coste de escritura: la tabla recibe un `INSERT ... ON DUPLICATE KEY UPDATE` por visita muestreada. No indexar columnas que se actualicen en cada escritura (como `hits`).

Controladores front del módulo

- Responder en `init()` y salir; no llamar a `parent::initContent()` en endpoints JSON: monta Smarty, header y footer para nada.
- Validar el token **antes** de cualquier trabajo, y compararlo con `hash_equals()`.

GravityShield (ecom_shield) - Documentation Master

Versión: 1.1.0

Autor: Ecom Experts

Licencia: AFL-3.0

Fecha Actualización: Febrero 2026

1. Introducción

GravityShield es un módulo avanzado de seguridad para PrestaShop diseñado para mitigar ataques distribuidos de bots, scraping y fuerza bruta en formularios críticos (registro y acceso). Combina técnicas de defensa pasiva (trampas), análisis de comportamiento (frecuencia) y filtrado geográfico.

2. Características Principales

- **Anti-Bot Distribuido:** Agrupación inteligente por IP y Contexto para detectar botnets que usan miles de IPs con pocos hits cada una.
- **Geo-Blocking:** Bloqueo estricto por países (ISO codes) con sistema de caché local para no penalizar el rendimiento.
- **Honeypot & Time-Trap:** Trampas invisibles en formularios de registro y login.
- **Análisis de Frecuencia:** Detección automática de bots basada en el tiempo promedio entre hits.
- **Mantenimiento Inteligente:** Herramientas para purgar "ruido" (hits individuales no sospechosos) y mantener la base de datos limpia.

3. Arquitectura Técnica

3.1. Base de Datos

Tabla: `ps_ecom_shield_log` - `ip`: Dirección IPv4/v6 del visitante. - `country_code`: Código ISO de país detectado (ES, US, etc.). - `hits`: Contador de peticiones agrupadas en ventanas de 1 hora. - `avg_interval`: Media aritmética del tiempo entre peticiones. - `is_bot`: Flag activado por firmas UA o frecuencia crítica (< 2s). - `blocked`: Estado de bloqueo del acceso. - `request_uri`: Última URL visitada por el sujeto.

3.2. Lógica de Agrupación

Para evitar la saturación de filas de "1 hit", el módulo busca registros previos por **IP + Contexto + Estado de Bloqueo** en la última hora. Si existe, actualiza el registro; si no, crea uno nuevo.

4. Sistema de Geolocalización

- **API Externa:** Utiliza `ip-api.com` para la resolución de IPs.

- **Caché Local:** Antes de consultar a la API, el módulo busca la IP en su propia tabla de logs.
- **Geo-Block Mode:** Si se activa, solo se permite el tráfico de los países definidos en `GRAVITY_ALLOWED_COUNTRIES` (por defecto: ES, US).

5. Detección de Amenazas

1. **Honeypot:** Input oculto `gs_trampa`. Si se recibe contenido, se bloquea.
2. **Time-Trap:** Token `gs_time` cifrado. Si la diferencia entre generación y envío es $< 3s$, se bloquea.
3. **Frecuencia:** Si `avg_interval` < 2.0 y `hits` > 3 , el registro se marca como `is_bot`.

6. Panel de Administración

- **Controlador:** `AdminEcomShieldLogController`
- **Acciones Masivas:**
 - **Limpiar Ruido:** Borra todos los logs de 1 solo hit que no son bloqueos ni bots.
 - **Purgar Normales:** Borra todo el tráfico monitorizado que no ha sido bloqueado.

7. Hooks Implementados

- `actionDispatcher` : Punto de entrada global para logging y geo-bloqueo.
- `displayCustomerAccountFormTop` : Inserción de trampas en el registro.
- `displayCustomerLoginFormAfter` : Inserción de trampas en el login.
- `actionSubmitAccountBefore` : Validación final antes de crear cuenta.

8. Configuración (Gmartos Connect)

El módulo incluye integración con el sistema de registro y actualizaciones de `modules.gmartos.es`, verificando la versión una vez por semana.

© 2026 Ecom Experts - Todos los derechos reservados.